

10/10/2025

Étude de Conformité RGPD : Cas de réservation d'hôtel en ligne.

Test S2 ISI_C06



utt
UNIVERSITÉ DE TECHNOLOGIE
TROYES



Responsable pédagogique :

Marc LEMERCIER

Shakira IPOULE
RT3

Contexte

Les réservations effectuées par les clients d'un hôtel, qu'elles concernent l'hébergement, la restauration, les activités de loisirs ou les services associés, impliquent la collecte et le traitement d'un grand volume de données, qu'elles soient **simples, personnelles ou sensibles**.

Or, ces données peuvent parfois être **communiquées à des tiers** (sociétés d'analyse, partenaires publicitaires, prestataires techniques) ou faire l'objet de **fuites** ou de **cyberattaques**, exposant ainsi les établissements hôteliers à des **risques juridiques importants** en cas de non-conformité au **Règlement Général sur la Protection des Données (RGPD)**.

Dans ce contexte, l'**hôtel B&B** m'a confiée la réalisation d'une **étude complète de conformité RGPD** de son **site web et de ses traitements associés**.

Cette mission vise à **identifier les données collectées, évaluer les traitements et les bases légales**, et **proposer des mesures de mise en conformité** afin d'assurer la **protection des données personnelles** de ses clients et de renforcer la **confiance numérique** dans les services en ligne de l'établissement.

L'analyse s'appuie sur les documents officiels de l'enseigne notamment la Politique de confidentialité et la Politique relative aux cookies ainsi que sur une simulation de navigation et de réservation effectuée sur l'application et le site web de B&B HOTELS, afin d'observer concrètement les flux et mécanismes de collecte de données.

1) Cartographie des données collectées

Suite à des recherches approfondies sur le site B&B HOTELS ainsi que sur ses politiques de confidentialité et de cookies, il apparaît que plusieurs **catégories de données** sont collectées de manière **directe** (par formulaire ou lors d'une réservation), **indirecte** (via des partenaires ou sous-traitants), ou **automatique** (par le biais de cookies et traceurs).

Ces données ont été **classées selon leur nature** afin d'évaluer leur niveau de sensibilité et les obligations associées en matière de protection :

- Les **données simples** sont des informations techniques ou générales qui ne permettent pas, à elles seules, d'identifier directement une personne (ex. type de chambre, langue du navigateur, nombre de nuitées).

- Les **données personnelles** concernent toute information se rapportant à une personne physique identifiée ou identifiable, directement (par son nom ou son e-mail) ou indirectement (par un identifiant, une adresse IP, un cookie).
- Les **données sensibles**, définies à l'article 9 du RGPD, regroupent les informations susceptibles de révéler notamment la santé, les convictions religieuses, les opinions politiques ou l'orientation sexuelle d'une personne (ex. allergies, contre-indications médicales pour le spa, remarques laissées dans un champ libre).

Le tableau ci-dessous présente la **cartographie complète des données collectées** par le site B&B HOTELS, classées selon ces catégories.

Un **commentaire** vient préciser les cas où la qualification du type de donnée est **subtile** ou où le **risque de non-conformité** est plus important.

Nom de la donnée	Description	Type de donnée	Commentaires
Nom	Nom de famille du client	Personnelle	R.A.S
Prénom	Prénom du Client	Personnelle	R.A.S
Civilité	M./Mme/Mlle/Mx	Personnelle	R.A.S
Date de naissance	Jour, mois, année de naissance	Personnelle	R.A.S
Nationalité	Pays d'origine	Personnelle	R.A.S
Adresse e-mail	Contact électronique	Personnelle	R.A.S
Téléphone	Contact téléphonique	Personnelle	R.A.S
Adresse postale	Rue, code postal, ville, pays	Personnelle	R.A.S
Noms des accompagnants	Nom(s) des personnes accompagnant le client lors du séjour	Personnelle	R.A.S
âges des accompagnants	Âge(s) des personnes accompagnant le client	Personnelle	R.A.S
Dates d'arrivée/départ	Période du séjour réservé	Personnelle	R.A.S
Nombre de nuitées	Durée du séjour	Simple	R.A.S
Nombre de chambres	Nombre de chambres réservées	Simple	R.A.S
Type de chambre	Simple, double, suite, ...	Simple	R.A.S

Type de literie	King, twin, queen,...	Simple	R.A.S
Présence d'animal de compagnie	Présence ou non d'animal de compagnie	Simple	R.A.S
Nombre de petits-déjeuners	Nombre de petits-déjeuners souhaités	Simple	R.A.S
Horaires des activités	Heures planifiées des activités du séjour	Simple	R.A.S
Loisirs réservés	Activités réservées (golf, visite, massage, spa, salle de sport,...)	Personnelle	R.A.S
Informations sur la santé (spa)	Informations médicales nécessaires pour certaines prestations (contre-indications)	Sensible	R.A.S
Allergies	Informations médicales relatives aux allergies alimentaires ou physiques	Sensible	R.A.S
Préférences particulières	Demandes spécifiques du client : parking, étage, vue , transferts	Personnelle	R.A.S
Numéro de carte bancaire	Numéro utilisé pour le paiement sécurisé	Personnelle	R.A.S
Date d'expiration carte	Date de validité de la carte de paiement	Personnelle	R.A.S
CVV	Code de sécurité figurant au dos de la carte	Personnelle	R.A.S
Titulaire de la carte	Nom sur la carte	Personnelle	R.A.S
Historique transactions	Paiements liés aux réservations	Personnelle	R.A.S
Adresse IP	Adresse réseau	Personnelle	R.A.S
Navigateur et OS	Type et version du navigateur et du système	Simple	R.A.S

	d'exploitation utilisés		
Appareil utilisé	Type d'appareil : Ordinateur, mobile, tablette	Simple	R.A.S
Langue navigateur	Langue choisie ou paramétrée dans le navigateur	Simple	R.A.S
Pages consultées/historique sur le site web	Liste des pages visitées sur le site web du service hôtelier	Personnelle	R.A.S
Cookies techniques	Nécessaires au fonctionnement du site pour le maintien de session, sécurité (PHPSESSID, rc::a, etc.)	Simple	R.A.S
Cookies de mesure d'audience(Dynatrace, New Relic, Google analytics)	Cookies servant à mesurer la fréquentation et les performances du site	Personnelle	R.A.S
Cookies publicitaires(ciblage/profilage : Google, Criteo, TikTok, Meta, etc.)	Cookies destinés à personnaliser les publicités selon le profil du visiteur (p. sensible)	Personnelle	Peut devenir sensible si le profilage ou la publicité ciblée révèle des informations liées aux opinions, à la religion, à la santé ou à la sexualité.
Cookies de personnalisation(langue, préférences)	Cookies mémorisant les choix de l'utilisateur (langue, affichage, préférences de contenu)	Personnelle	R.A.S
CMP(cookiebot/OneTrust)	Gestion du consentement cookies	Personnelle	
Géolocalisation	Position géographique du client si	Personnelle	R.A.S

	l'autorisation est activée		
Identifiants compte client	Identifiants de connexion : adresse e-mail et mot de passe du compte	Personnelle	R.A.S
Numéro de fidélité	Identifiant unique attribué au membre d'un programme fidélité	Personnelle	R.A.S
Statut / solde points	Niveau de fidélité et nombre de points cumulés	Personnelle	R.A.S
Offres personnalisées	Offres marketing adaptées au profil et aux préférences du client	Personnelle	R.A.S
Avis / feedback	Commentaires et notes laissés après un séjour	Personnelle	Peut contenir des données sensibles saisies librement
Historique de séjour	Liste des séjours précédents et détails associés	Personnelle	R.A.S
Réclamations/incidents	Signalements de problèmes ou demandes d'assistance/SAV	Personnelle	Champs libres pouvant contenir des informations personnelles ou sensibles

2) Collecte de données sensibles

Dans le tableau récapitulatif des données collectées, certaines informations traitées par le site B&B HOTELS peuvent être qualifiées de **données sensibles**, au sens des « catégories particulières de données à caractère personnel » définies par le Règlement Général sur la Protection des Données (RGPD).

Il s'agit principalement des **informations relatives à la santé** ou aux **allergies** communiquées par les clients lors de la réservation ou de la préparation du séjour.

Exemples :

- Une cliente signale une **allergie alimentaire** (ex. fruits à coque) afin que le personnel adapte le petit-déjeuner et évite tout risque allergique.
- Un client informe le service spa d'un problème de santé (ex. hypertension, troubles cardiaques) pour adapter le type de massage ou de soins proposés.

De plus, certains **champs libres** présents sur le site (formulaire de contact, réclamation, avis client) peuvent accidentellement contenir des **données sensibles**, si le client y évoque des éléments relatifs à sa **santé**, sa **religion**, ses **opinions** ou son **orientation sexuelle**.

Conformément à l'**article 9 du RGPD**, sont considérées comme données sensibles les informations « révélant l'origine raciale ou ethnique, les opinions politiques, les convictions religieuses ou philosophiques, l'appartenance syndicale, ainsi que les données génétiques, biométriques, de santé ou relatives à la vie sexuelle ou à l'orientation sexuelle ».

Leur traitement est **interdit**, sauf si la personne concernée donne son **consentement explicite** pour une **finalité précise et légitime**, comme l'adaptation d'un service ou la prévention d'un risque pour sa santé.

3) Buts/ Finalités des traitements

Les données à caractère personnel collectées par B&B HOTELS sont traitées pour des **finalités déterminées, explicites et légitimes**, conformément à l'article 5, paragraphe 1, point b) du RGPD.

Ces traitements visent à **assurer la gestion opérationnelle des séjours**, à **améliorer la qualité de service**, et à **garantir une expérience client personnalisée et sécurisée**, dans le respect du principe de **privacy by design**.

Les **données d'identification et de contact** (nom, prénom, adresse postale, téléphone, e-mail) sont utilisées pour :

- créer et gérer le **compte client** ;
- assurer le **suivi des réservations** et la **communication** avant, pendant et après le séjour ;

- établir la **facturation** et répondre aux **obligations contractuelles** et légales.

Les **données bancaires** (numéro, date d'expiration, titulaire) sont collectées pour :

- **traiter les paiements** via un prestataire certifié **PCI DSS**,
- **sécuriser les transactions** et lutter contre la fraude,
- et satisfaire aux **obligations comptables et fiscales** de l'établissement.

Les **informations de santé** (ex. allergies, contre-indications médicales pour le spa) sont recueillies sur une base **volontaire** afin d'adapter les prestations et **garantir la sécurité du client**.

Ces données sont **strictement limitées** à leur finalité et **supprimées après le séjour**, conformément au principe de **minimisation**.

Les **données de navigation et cookies** (adresse IP, préférences linguistiques, identifiants de session, cookies publicitaires ou analytiques) servent à :

- assurer le **bon fonctionnement technique** du site (cookies nécessaires) ;
- mesurer la fréquentation et améliorer l'ergonomie via **Dynatrace, New Relic** ou **Google Analytics** (cookies soumis au consentement) ;
- personnaliser l'affichage et proposer des publicités ciblées via des partenaires tels que **Google, Meta, Criteo** ou **TikTok**.

Certains prestataires, tels que **Google** ou **Hotels at Home Inc.**, sont situés hors de l'Espace économique européen. Les transferts de données correspondants sont encadrés par **les Clauses Contractuelles Types (SCC)** ou par le **Data Privacy Framework (DPF)** afin de garantir un niveau de protection adéquat.

Les **avis clients, réclamations et incidents** sont utilisés pour la **gestion de la relation client**, le **suivi de satisfaction**, et la **prévention des litiges**.

Enfin, sous réserve du **consentement du client**, ses coordonnées peuvent être utilisées à des **fins de prospection commerciale**, notamment pour l'envoi de **newsletters**, d'**offres promotionnelles personnalisées** ou d'**actualités** sur les établissements du groupe.

Dans tous les cas, **B&B HOTELS** applique le principe de **minimisation** : seules les données nécessaires à chaque finalité sont collectées, et leur durée de conservation est strictement limitée.

4) Bases légales des traitements

Conformément à l'article 6 du **Règlement Général sur la Protection des Données (RGPD)**, les traitements de données personnelles effectués par **B&B HOTELS** reposent sur des bases juridiques clairement identifiées, garantissant leur licéité.

- **Exécution du contrat (article 6, paragraphe 1, point b)**

Cette base justifie le traitement des données nécessaires à la **gestion des réservations**, à la **communication avec les clients** et à la **fourniture des prestations hôtelières et commerciales**.

Les informations traitées incluent les **données d'identification, de contact, de réservation et de paiement**.

Ces traitements permettent à B&B HOTELS de **confirmer et exécuter les réservations**, d'assurer la **prestation des services réservés** (hébergement, restauration, spa) et d'émettre la **facturation** correspondante.

Les données peuvent provenir directement du site **bbhotelsboutique.com** ou de **plateformes partenaires** (ex. **Booking.com**), qui transmettent uniquement les éléments nécessaires à la gestion du séjour.

- **Obligation légale (article 6, paragraphe 1, point c)**

Certaines données sont traitées pour répondre à des **obligations légales et réglementaires** imposées à l'établissement, telles que :

- la **conservation des documents comptables et fiscaux** ;
- la **tenue du registre des clients** prévu par les autorités locales ;
- ou encore la **coopération avec les forces de l'ordre** en cas de réquisition légale.

- **Consentement explicite (articles 6, paragraphe 1, point a, et 9, paragraphe 2, point a)**

Les **informations sensibles**, telles que les **allergies alimentaires** ou les **contre-indications médicales** pour certaines prestations (ex. spa, restauration), sont traitées sur la base du **consentement explicite du client**.

Ce consentement est recueilli avant tout traitement et peut être retiré à tout moment.

Ces données sont utilisées uniquement pour **adapter les services aux besoins du client**, et supprimées une fois la finalité atteinte, conformément au principe de **minimisation**.

- **Intérêt légitime (article 6, paragraphe 1, point f)**

B&B HOTELS peut traiter certaines données dans le cadre de son **intérêt légitime**, notamment pour :

- la **gestion de la relation client** (réclamations, service après-vente, amélioration des services) ;
- la **sécurisation des transactions** et la **prévention des fraudes** ;

- ou la **gestion interne des opérations** liées à l'exploitation du site.
Ces traitements sont réalisés dans le respect des **droits et libertés** des personnes concernées.

• **Consentement (article 6, paragraphe 1, point a)**

Le traitement des données à des **fins de prospection commerciale** (newsletters, offres promotionnelles, campagnes marketing) repose sur le **consentement préalable du client**. Ce consentement peut être retiré à tout moment via le lien de désinscription figurant dans chaque communication ou par contact direct avec le service client.

De même, l'utilisation de **cookies non essentiels** (analyse, personnalisation, publicité) est fondée sur le **consentement explicite** recueilli via le **bandeau de gestion Cookiebot**, tandis que les **cookies strictement nécessaires** (fonctionnement du site, sécurité, session) sont exemptés de cette exigence.

• **Transferts de données hors de l'Union européenne**

Certains traitements peuvent entraîner des **transferts de données hors de l'Espace Économique Européen**, notamment :

- vers **Hotels at Home Inc.** (États-Unis), prestataire chargé du traitement des commandes et des e-mails marketing,
- et vers des **partenaires techniques** comme **Google LLC** pour la mesure d'audience et la gestion des cookies analytiques.
Ces transferts sont encadrés par les **Clauses Contractuelles Types (SCC)** ou par le **Data Privacy Framework (DPF)**, assurant un niveau de protection adéquat des données personnelles.

Synthèse :

Finalité	Base juridique	Commentaires
Réservation, communication, facturation	Exécution du contrat	Données collectées directement ou via Booking.com
Obligations comptables et légales	Obligation légale	Conservation et transmission imposées par la loi
Allergies, contre-indications spa	Consentement explicite	Collecte volontaire et finalité de sécurité du client

Gestion de la relation client, prévention de fraude, sécurité	Intérêt légitime	Amélioration de la qualité, prévention d'incidents
Prospection, cookies analytiques/publicitaires	Consentement	Gestion via Cookiebot, preuve de choix conservée
Transferts vers prestataires externes (hors UE)	Garanties contractuelles Types / DPF	Hotels at Home Inc., Google LLC

5) Durée de conservation de données

Conformément à l'article 5, paragraphe 1, point e) du **Règlement Général sur la Protection des Données (RGPD)**, les données à caractère personnel sont conservées sous une forme permettant l'identification des personnes concernées **uniquement pendant la durée nécessaire à la réalisation des finalités** pour lesquelles elles ont été collectées. Au-delà de cette période, les données sont soit **supprimées**, soit **anonymisées** à des fins statistiques ou d'archivage.

Les durées de conservation appliquées par **B&B HOTELS** découlent à la fois :

- des **exigences légales et réglementaires** (fiscales, comptables, sécurité publique),
- et des **bonnes pratiques internes** de gestion des relations clients.

• Données relatives à la réservation et au séjour

Les données nécessaires à la **gestion des réservations** (nom, coordonnées, dates, préférences, historique de séjour) sont conservées **pendant toute la durée de la relation contractuelle**, puis **archivées pendant 5 ans** à compter de la fin du séjour.

Cette durée permet de traiter d'éventuelles **réclamations** ou **litiges**, conformément aux **délais de prescription civile** applicables.

• Données de facturation et de paiement

Les **données financières et comptables** (factures, justificatifs de paiement, transactions) sont conservées pendant **10 ans**, en application des **obligations légales en matière comptable et fiscale** (article L123-22 du Code de commerce).

Les **données de carte bancaire** sont conservées uniquement **jusqu'au complet paiement** ou à la **fin de la prestation**, sauf archivage intermédiaire pour la gestion d'un contentieux (13 à 15 mois maximum).

Les **cryptogrammes visuels (CVV)** sont supprimés immédiatement après la transaction.

• Données de santé (allergies, contre-indications spa)

Les informations relatives à la santé, communiquées **volontairement** par le client dans le cadre d'une prestation spécifique (restauration, spa, etc.), sont conservées **uniquement pendant la durée du séjour ou de la prestation concernée**, puis **supprimées à son issue**.

Une conservation plus longue n'est possible **que sur demande expresse du client** (ex. souhait de conserver l'information pour un futur séjour).

Ces données sont **pseudonymisées** et **limitées strictement à la finalité de sécurité ou de confort** du client.

- **Données liées à la relation client (avis, réclamations, correspondances)**

Les données issues des **formulaires de contact, avis clients ou réclamations** sont conservées pour une durée maximale de **3 ans à compter du dernier contact**.

Elles servent à assurer un **suivi qualitatif du service** et à gérer d'éventuels **litiges** liés à la relation client.

- **Données utilisées à des fins de prospection commerciale**

Les données exploitées à des **fins marketing** (newsletters, offres promotionnelles, programmes de fidélité) sont conservées **3 ans à compter du dernier contact** ou de la dernière interaction (ex. ouverture d'un e-mail), sauf retrait du consentement avant ce délai.

En cas de désinscription, seules les données minimales nécessaires à la **gestion de la preuve du consentement** et du **retrait** sont conservées pour éviter tout envoi ultérieur.

- **Données de connexion et de navigation**

Les données issues de la **navigation sur le site web** (adresses IP, cookies, identifiants de session) sont conservées selon leur finalité :

- **Cookies nécessaires** : durée variable selon leur fonction (de la session à 400 jours);
- **Cookies analytiques et marketing** : **13 mois maximum**, conformément aux recommandations de la CNIL ;
- **Consentement de l'utilisateur (via Cookiebot)** : conservé pendant **1 an** comme preuve du choix exprimé.

- **Transferts et conservation chez les sous-traitants**

Les données traitées par les **prestataires techniques** (ex. *Hotels at Home Inc., Google LLC*) sont conservées selon les **mêmes durées** que celles appliquées par B&B HOTELS et encadrées par des **clauses contractuelles types (SCC)**.

Les prestataires sont tenus de **supprimer ou anonymiser** les données à l'issue des durées contractuelles, conformément au **principe de minimisation**.

Synthèse :

Catégorie de données	Durée de conservation	Fondement / Référence
Réservation et séjour	Durée du contrat + 5 ans	Prescription civile (gestion des litiges)
Facturation et paiement	10 ans	Obligation légale comptable et fiscale
Données de santé (allergies, spa)	Durée de la prestation	Consentement explicite – finalité de sécurité
Relation client (avis, réclamations)	3 ans à compter du dernier contact	Suivi qualité / gestion de litiges
Prospection commerciale	3 ans ou jusqu'au retrait du consentement	Consentement (article 6 §1 a)
Données de connexion / cookies	13 mois maximum	Recommandation CNIL / CMP Cookiebot
Preuve de consentement (Cookiebot)	1 an	RGPD – traçabilité du choix utilisateur

6) Destinataires des données et transmission à des tiers

Les données à caractère personnel collectées par **B&B HOTELS** sont traitées de manière **strictement confidentielle** et ne sont accessibles qu'aux **personnes habilitées** à en connaître dans le cadre de leurs fonctions.

Toute communication à un tiers est encadrée par des **accords contractuels** conformes aux exigences du **RGPD** et repose sur le **principe de nécessité et de minimisation**.

• Personnel interne de l'hôtel

Seuls les **membres du personnel autorisés** (réception, restauration, direction, service client, comptabilité, spa, maintenance) ont accès aux données personnelles des clients, dans la limite de leurs missions :

- gestion des réservations et de l'accueil,
- facturation et suivi des paiements,
- communication avec le client avant, pendant et après le séjour,
- traitement des réclamations ou incidents.

L'accès est contrôlé par des **droits d'utilisateur restreints** et soumis à des **obligations de confidentialité**.

• Prestataires et sous-traitants techniques

Certaines données peuvent être transmises à des **prestataires agissant pour le compte de B&B HOTELS**, dans le cadre de services techniques ou opérationnels.

Ces sous-traitants interviennent uniquement **sur instruction documentée de B&B HOTELS**, conformément à l'article 28 du RGPD, et sont liés par des **clauses contractuelles strictes** garantissant la sécurité et la confidentialité des données.

Les principales catégories de sous-traitants sont :

- **Hotels at Home SAS / Inc.** : gestion des commandes, du site e-commerce, de la logistique et de la relation client. La filiale américaine (*Hotels at Home Inc.*, située aux États-Unis) peut intervenir pour le traitement des commandes et l'envoi d'e-mails marketing.
- **Fournisseurs de solutions de paiement** : traitement sécurisé des transactions bancaires via des prestataires conformes à la norme **PCI DSS**.
- **Prestataires informatiques et d'hébergement** : maintenance, hébergement et sécurité du site web, y compris les solutions cloud associées.
- **Prestataires d'analyse et de performance** : outils tels que **Google Analytics**, **New Relic** et **Dynatrace**, utilisés pour la mesure d'audience et l'optimisation du site (sous réserve du consentement des utilisateurs).
- **Fournisseur de gestion du consentement (Cookiebot)** : collecte et stockage des choix des utilisateurs relatifs aux cookies, conformément aux exigences de la CNIL.
- **Prestataires marketing** : envoi de newsletters et de communications promotionnelles, sur la base du consentement du client.

• **Partenaires commerciaux**

B&B HOTELS peut également recevoir ou partager certaines données avec ses **partenaires commerciaux** lorsque cela est nécessaire à la gestion du séjour ou à la fourniture de services complémentaires.

Cela concerne notamment :

- les **plateformes de réservation** telles que **Booking.com** ou **Expedia**, qui transmettent les informations nécessaires à la gestion de la réservation (identité, coordonnées, dates de séjour, préférences) ;
- les **partenaires touristiques ou prestataires locaux** (agences, transporteurs, activités de loisirs), uniquement avec le **consentement préalable du client**. Ces échanges de données ont pour finalité exclusive la **bonne exécution des prestations réservées** et sont encadrés par des **contrats de coresponsabilité ou de sous-traitance**.

• **Autorités administratives ou judiciaires**

B&B HOTELS peut être tenu de communiquer certaines informations à des **autorités publiques** (ex. police, gendarmerie, services fiscaux) lorsque la loi l'exige, notamment dans le cadre :

- du **registre des clients** obligatoire pour les établissements hôteliers,
- d'enquêtes administratives ou judiciaires,
- ou de toute **obligation légale de sécurité publique**.

- **Transferts de données hors de l'Union européenne**

Certains traitements peuvent impliquer des **transferts de données hors de l'Espace Économique Européen**, notamment vers :

- **Hotels at Home Inc. (États-Unis)**, pour la gestion du site et des communications marketing,
- **Google LLC (États-Unis)**, pour l'analyse du trafic et la mesure d'audience,
- ou d'autres prestataires techniques intervenant dans la chaîne de service numérique.

Ces transferts sont **encadrés par les Clauses Contractuelles Types (SCC)** de la Commission européenne ou par le **Data Privacy Framework (DPF)**, garantissant un niveau de protection équivalent à celui exigé par le RGPD.

7) Information des clients sur la collecte et l'utilisation de leurs données

Conformément aux articles 12 à 14 du **Règlement Général sur la Protection des Données (RGPD)**, B&B HOTELS assure une **information claire, transparente et accessible** des clients concernant la collecte et l'utilisation de leurs données personnelles.

Cette transparence constitue un élément essentiel de la conformité RGPD du groupe.

- **Modalités d'information des clients**

Les clients sont informés de la collecte et du traitement de leurs données à plusieurs moments du parcours utilisateur :

- lors de la **navigation sur le site web** (hotel-bb.com ou bbhotelsboutique.com), via des mentions légales et une **politique de confidentialité** détaillant les finalités, la base légale, la durée de conservation et les destinataires ;
- via le **bandeau de consentement Cookiebot**, qui décrit les différentes catégories de cookies (nécessaires, analytiques, marketing) et permet de gérer les préférences ;

- au moment de la **réservation en ligne**, où les champs de collecte sont clairement identifiés et accompagnés d'un lien vers la politique de confidentialité ;
- et lors de la **communication marketing**, chaque e-mail promotionnel contenant un lien de désinscription et rappelant les droits du client.

Toutes les informations sont rédigées dans un **langage simple et compréhensible**, conformément à l'article 12 du RGPD.

• Contenu de l'information fournie

Les politiques et formulaires utilisés par **B&B HOTELS** précisent notamment :

- l'**identité du responsable du traitement** (B&B HOTELS, en sa qualité de responsable de traitement),
- les **finalités et bases légales** des traitements,
- les **catégories de données collectées** (identité, coordonnées, données de navigation, préférences, etc.),
- les **destinataires** internes et externes (personnel autorisé, prestataires techniques, partenaires commerciaux),
- les **transferts éventuels hors de l'Union européenne** (notamment vers **Hotels at Home Inc.** et **Google LLC**, encadrés par les **Clauses Contractuelles Types** ou le **Data Privacy Framework**),
- la **durée de conservation** des données selon leur finalité,
- les **droits reconnus** aux personnes concernées (accès, rectification, suppression, limitation, opposition, portabilité, retrait du consentement),
- et les **coordonnées de contact** du délégué à la protection des données (DPO).

Cette information est disponible en ligne, mise à jour régulièrement, et consultable à tout moment depuis le site ou les communications électroniques de l'hôtel.

• Information spécifique sur les cookies

Le site de **B&B HOTELS** utilise différents types de cookies et traceurs :

- **cookies strictement nécessaires**, exemptés de consentement, permettant le fonctionnement du site,

- **cookies analytiques et de performance**, utilisés pour mesurer la fréquentation via **Google Analytics, Dynatrace** ou **New Relic**, activés uniquement après consentement,
- **cookies marketing et de personnalisation**, destinés à afficher des publicités ciblées via **Google, Meta, Criteo, TikTok**, etc.

L'utilisateur est informé dès son arrivée sur le site grâce au **bandeau Cookiebot**, qui lui permet de **paramétrer son consentement par catégorie**.

Le choix exprimé est conservé pendant **12 mois**, et peut être modifié à tout moment via le lien « Gérer mes cookies » présent en bas de page.

• **Information lors des transferts de données**

Lorsque les données sont susceptibles d'être **transférées hors de l'Union européenne**, **B&B HOTELS** en informe explicitement le client dans sa politique de confidentialité.

Les transferts sont **encadrés par des garanties légales appropriées**, notamment les **Clauses Contractuelles Types (SCC)** ou l'**adhésion au Data Privacy Framework (DPF)** pour les prestataires situés aux États-Unis.

• **Droit à l'information renforcé**

Les clients peuvent à tout moment consulter la politique de confidentialité de **B&B HOTELS** ou **contacter le délégué à la protection des données (DPO)** pour obtenir des informations complémentaires sur les traitements effectués ou sur leurs droits.

Les coordonnées du DPO figurent en fin de politique de confidentialité, conformément à l'article 13 du RGPD.

8) **Prise en compte et exercice des droits des clients**

Conformément aux **articles 12 à 23 du Règlement Général sur la Protection des Données (RGPD)**, **B&B HOTELS** garantit à ses clients l'exercice effectif de leurs droits relatifs à leurs données personnelles.

Ces droits visent à assurer la **transparence**, la **maîtrise** et la **protection** des informations traitées par l'établissement ou ses sous-traitants.

• **Droits reconnus aux clients**

- **Droit d'accès (article 15)**

Chaque client peut obtenir la confirmation que des données personnelles le

concernant sont traitées par B&B HOTELS, et en recevoir une copie accompagnée d'informations sur la finalité du traitement, les catégories de données, les destinataires et la durée de conservation.

- **Droit de rectification (article 16)**

Les clients peuvent demander la correction ou la mise à jour de leurs données personnelles lorsqu'elles sont inexactes, incomplètes ou obsolètes.

- **Droit à l'effacement ("droit à l'oubli") (article 17)**

Les clients peuvent solliciter la suppression de leurs données lorsque celles-ci ne sont plus nécessaires aux finalités initiales, lorsqu'ils retirent leur consentement, ou lorsque le traitement est illicite.

- **Droit à la limitation du traitement (article 18)**

Les clients peuvent demander la suspension temporaire de l'utilisation de leurs données, notamment le temps de vérifier leur exactitude ou la légitimité du traitement.

- **Droit d'opposition (article 21)**

Les clients peuvent s'opposer, à tout moment, au traitement de leurs données à des fins de prospection commerciale (ex. : envoi d'offres promotionnelles, newsletters) ou lorsque celui-ci repose sur l'intérêt légitime de B&B HOTELS.

- **Droit à la portabilité (article 20)**

Le client peut obtenir une copie de ses données dans un format structuré, couramment utilisé et lisible par machine, afin de les transférer à un autre responsable de traitement.

- **Droit de retrait du consentement (article 7, paragraphe 3)**

Lorsque le traitement repose sur le consentement (par exemple pour les cookies marketing, la réception de newsletters, ou les données de santé liées à certaines prestations), le client peut le retirer à tout moment sans justification ni incidence sur la prestation principale.

- **Modalités d'exercice des droits**

B&B HOTELS a mis en place une procédure interne de gestion des demandes d'exercice des droits, assurée par le **Global Data Protection Manager** du groupe.

Les demandes peuvent être adressées :

- **Par email** à : [privacy@hotelbb.com] ou [customer.service@bbhotelsboutique.com]
- **Par courrier postal** à :
HOTELS AT HOME – Global Data Protection Manager

*163, rue de la Belle Étoile – Business Park Paris Nord 2 – Bât. 6B
95700 ROISSY EN FRANCE – France*

- **Ou directement à la réception de l'hôtel**, où le personnel formé peut accompagner le client dans sa démarche.

Une **pièce d'identité** peut être demandée afin de vérifier l'identité du demandeur, conformément à l'article 12, paragraphe 6 du RGPD.

B&B HOTELS s'engage à répondre dans un **délai maximal d'un mois** à compter de la réception de la demande.

Ce délai peut être prolongé de **deux mois supplémentaires** en cas de complexité ou de nombre important de demandes, conformément à l'article 12, paragraphe 3.

Le client est alors informé de cette prolongation et des raisons du report.

En cas de désaccord ou de difficulté non résolue, le client peut introduire une **réclamation auprès de la CNIL** :

Commission Nationale de l'Informatique et des Libertés (CNIL)

3 Place de Fontenoy – TSA 80715 – 75334 Paris Cedex 07

www.cnil.fr

- **Engagement de B&B HOTELS**

B&B HOTELS s'engage à :

- informer clairement ses clients de leurs droits **au moment de la collecte**, notamment via les politiques en ligne et les formulaires de réservation ;
- **former régulièrement le personnel** à la gestion des demandes RGPD et à la confidentialité des données clients ;
- **conserver une traçabilité des réponses** apportées aux clients, afin de démontrer sa conformité au principe d'**accountability** (article 5, paragraphe 2 du RGPD) ;
- et **intégrer la gestion des droits** dès la conception de ses outils numériques, conformément au principe de "**privacy by design et by default**".

9) Point de contact dédié à la protection des données personnelles

Afin de garantir la **bonne application du Règlement Général sur la Protection des Données (RGPD)** et d'assurer la **transparence vis-à-vis de sa clientèle**, **B&B HOTELS** a

désigné un **Délégué à la Protection des Données (DPO)**, également appelé *Global Data Protection Manager*.

Ce responsable est chargé de superviser la conformité du groupe et de veiller à ce que le traitement des données personnelles respecte les principes du RGPD, la législation nationale applicable, ainsi que les standards internes du groupe B&B HOTELS.

• Rôle et responsabilités

Le **DPO / Global Data Protection Manager** est notamment chargé de :

- **veiller à la conformité** des traitements de données mis en œuvre par B&B HOTELS et ses sous-traitants ;
- **répondre aux demandes des clients** relatives à l'exercice de leurs droits (accès, rectification, effacement, opposition, portabilité, etc.) ;
- **conseiller la direction et le personnel** sur les bonnes pratiques en matière de protection des données et de sécurité informatique ;
- **contrôler la mise à jour des politiques internes** de protection des données et leur conformité au RGPD ;
- et **servir d'intermédiaire avec la CNIL** ou toute autre autorité de contrôle compétente en cas de besoin.

Ce rôle s'inscrit dans le cadre du principe d'**accountability** (article 5, paragraphe 2 du RGPD) et du principe de "**privacy by design et by default**", garantissant l'intégration de la protection des données dès la conception des services numériques et hôteliers.

• Coordonnées du DPO

Les clients peuvent contacter le Délégué à la Protection des Données de **B&B HOTELS** pour toute question relative au traitement de leurs données personnelles ou à l'exercice de leurs droits :

Par email :

privacy@hotelbb.com

ou *customer.service@bbhotelsboutique.com*

Par courrier postal :

HOTELS AT HOME – Global Data Protection Manager

163, rue de la Belle Étoile – Business Park Paris Nord 2 – Bât. 6B

95700 ROISSY EN FRANCE – France

Ces coordonnées figurent également dans la **politique de confidentialité** accessible sur le site internet officiel de **B&B HOTELS** et dans les communications adressées aux clients.

- **Communication avec les autorités**

Le **DPO** agit également comme **point de contact principal** entre **B&B HOTELS** et les autorités de protection des données, notamment la **CNIL** (France) et ses équivalents européens, en cas de contrôle, de notification de violation ou de demande d'information.

10) Mise en place de mesures de sécurité

Conformément à l'article 32 du **RGPD**, **B&B HOTELS** met en œuvre des **mesures techniques et organisationnelles appropriées** pour garantir la **confidentialité**, **l'intégrité et la disponibilité** des données personnelles, et prévenir toute **perte, altération, divulgation ou accès non autorisé** (données numériques et papier).

Mesures organisationnelles (déclarées)

- **Accès limité et habilitations** : seuls les personnels autorisés (réception, direction, service client, comptabilité, restauration/spa) accèdent aux données nécessaires à leurs missions, sous **engagement de confidentialité**.
- **Encadrement des sous-traitants** : les prestataires (**Hotels at Home SAS/Inc., Cookiebot, Google/Analytics, New Relic, Dynatrace, prestataires de paiement PCI-DSS**) agissent **sur instruction** et sont **contractuellement tenus** à la sécurité/confidentialité (art. 28 RGPD).
- **Gouvernance** : supervision par le **Global Data Protection Manager** (point de contact officiel indiqué dans la politique de confidentialité).
- **Minimisation "by design"** : pour les formulaires essentiels (ex. commande), **les champs obligatoires sont limités au minimum** ; les informations sensibles ne sont collectées qu'en cas de besoin explicite.

Mesures techniques (déclarées)

- **Chiffrement des échanges** : transmission **HTTPS/TLS** pour les données personnelles ; pour les données de carte, **canaux chiffrés** et exigences **PCI-DSS**.
- **Environnement interne protégé** : traitements internes **au sein d'un VPN, protégé par pare-feu**, avec communications **chiffrées**.

- **Contrôles de sécurité Web** : cookies de session nécessaires (ex. PHPSESSID), dispositifs anti-bot (**reCAPTCHA**, classé “nécessaire”), et cache applicatif (ex. X-Magento-Vary).
- **Gestion des cookies et consentement (CMP)** :
 - **Cookies nécessaires** (fonctionnement/sécurité) : **exemptés de consentement**.
 - **Cookies analytiques/marketing** (ex. Google Analytics, partenaires pub) : **déposés uniquement après consentement** explicite via le **bandeau Cookiebot** ; le **consent ID** est conservé (cookie de preuve).
 - L'utilisateur peut **modifier/retirer** ses choix à tout moment depuis le lien footer prévu à cet effet.

Gestion des incidents (cadre RGPD)

B&B HOTELS indique appliquer des **procédures internes et mesures robustes** de sécurité. En cas de **violation de données présentant un risque**, l'établissement s'engage à respecter le cadre légal :

- **Notification à l'autorité** compétente **dans les 72 h** (art. 33 RGPD),
- **Information des personnes** en cas de risque élevé (art. 34 RGPD).

Relations avec les sous-traitants / transferts hors UE

- Interventions de **Hotels at Home Inc. (États-Unis)** pour certaines opérations (site/commandes/emails marketing) et de **Google LLC** pour l'analytics/ads : **Transferts encadrés** (Clauses Contractuelles Types / mécanismes d'adéquation applicables).
- Les prestataires s'engagent à respecter un **niveau de protection adéquat** ; le **Global Data Protection Manager** en assure le suivi.

Tableau récapitulatif des non-conformités et actions correctives(classées par priorité)

N°	Problème identifié / Non-conformité	Niveau de priorité	Impact sur la conformité / les personnes	Mesures correctives proposées (détaillées)
----	-------------------------------------	--------------------	--	--

1	Absence de consentement explicite formalisé pour les données sensibles (santé, allergies, contre-indications spa)	Haute	Risque de traitement illicite de données sensibles (article 9 RGPD). Le consentement du client n'est pas démontrable, ce qui pourrait constituer une violation grave du RGPD et exposer l'hôtel à des sanctions.	Créer un formulaire spécifique ou une case de consentement explicite à cocher pour toute collecte d'informations de santé. Mentionner la finalité ("adapter les prestations de restauration/spa aux besoins du client"). Conserver une preuve du consentement (date, identifiant, finalité). Supprimer ces données à la fin du séjour. Former le personnel à ne pas collecter ces données sans demande volontaire du client.
2	Mécanisme de gestion des cookies partiellement documenté (présence d'un bandeau Cookiebot mais transparence perfectible sur le dépôt effectif)	Haute	Risque de non-respect de l'article 82 de la loi Informatique & Libertés (transposition de la directive ePrivacy). Si certains cookies analytiques ou marketing sont déposés avant consentement, cela constitue une violation.	Vérifier le paramétrage du Tag Manager pour bloquer tous les cookies non essentiels avant consentement. Maintenir un journal des consentements Cookiebot (Consent ID, date, version). Mettre à jour la politique de cookies avec les durées précises et les finalités de chaque cookie tiers (Google, Meta, Criteo, etc.). Afficher clairement les boutons "Tout refuser / Tout accepter".
3	Transferts hors Union européenne décrits de façon générale, sans liste consolidée des prestataires concernés	Haute	Risque d'insuffisance de transparence (articles 13 et 14 RGPD). Les clients ne peuvent pas identifier clairement vers quels pays ou prestataires leurs	Ajouter dans la politique de confidentialité une section "Transferts internationaux" listant les prestataires impliqués (Hotels at Home Inc., Google LLC, New Relic, Dynatrace, Meta,

			données sont transférées.	Criteo). Indiquer pour chacun le mécanisme d'encadrement juridique (SCC, DPF, décision d'adéquation). Mentionner la possibilité pour le client de demander plus d'informations au DPO.
4	Absence d'un registre des traitements interne publié ou référencé dans les documents disponibles	Haute	Non-respect du principe d'accountability (article 30 RGPD). L'hôtel ne pourrait pas démontrer sa conformité ni identifier précisément les finalités, durées et destinataires de chaque traitement.	Formaliser un registre des traitements recensant : les finalités, bases légales, catégories de données, durées de conservation, destinataires, mesures de sécurité et transferts hors UE. Le tenir à jour annuellement. Permettre au DPO d'en assurer le suivi centralisé pour l'ensemble du groupe B&B HOTELS.
5	Mesures techniques avancées (chiffrement au repos, 2FA, journaux d'accès) non documentées publiquement	Moyenne	L'absence de documentation publique ne prouve pas nécessairement une faille, mais empêche de démontrer la conformité à l'article 32 RGPD. L'hôtel pourrait être jugé insuffisamment transparent en cas d'audit CNIL.	Documenter dans la politique de sécurité (interne) ou dans un addendum RGPD les mesures mises en œuvre : chiffrement AES des bases clients, sauvegardes chiffrées, authentification à deux facteurs pour le back-office, gestion des logs d'accès. Mentionner publiquement les principes sans divulguer la configuration technique.
6	Procédure de gestion des violations de données non détaillée dans la	Moyenne	Risque de retard de notification en cas d'incident, non-conformité aux articles 33 et 34 du RGPD.	Rédiger une procédure interne d'incident : détection, qualification, notification à la CNIL sous 72 h, information des personnes si

	politique publique			nécessaire, mesures correctives post-incident. Ajouter un encadré public dans la politique : “En cas d’incident de sécurité affectant vos données, nous vous informerons dans les plus brefs délais, conformément à l’article 34 du RGPD.”
7	Liste incomplète des sous-traitants (hors cookies) dans la politique de confidentialité	Moyenne	Transparence partielle sur les partenaires non-cookies (hébergeur, prestataires de paiement, services cloud). Cela réduit la capacité du client à comprendre le parcours complet de ses données.	Ajouter un tableau clair des catégories de sous-traitants : hébergement web (ex. AWS/OVH), prestataire de paiement (norme PCI-DSS), service marketing (Hotels at Home), outil d’analyse (Google Analytics). Pour chaque, préciser la finalité, la base légale et les garanties contractuelles.
8	Preuve du consentement (cookie de preuve) non explicitée dans la politique de confidentialité	Moyenne	Accountability incomplète : l’hôtel prouve la conformité via Cookiebot, mais le client n’est pas informé de la durée ou de l’utilisation de ce “journal de consentement”.	Préciser dans la politique : “Les preuves de consentement (Consent ID, date, version) sont conservées 13 mois à des fins de conformité et peuvent être communiquées sur demande à la CNIL ou à la personne concernée.”
9	Champs libres (formulaire de contact, réclamations, avis clients) pouvant contenir des données sensibles non sollicitées	Moyenne	Risque de collecte non maîtrisée de données sensibles (santé, convictions, orientation). Cela peut rendre le traitement illicite.	Ajouter un avertissement : “Merci de ne pas inclure d’informations de nature sensible (santé, religion, opinions, etc.) dans vos messages.” Filtrer automatiquement ces champs via une modération ou un masquage de mots-clés

				sensibles dans le back-office.
10	Politique de confidentialité très complète mais dense et peu lisible pour un client non expert	Faible	Risque de non-conformité au critère de “langage clair et compréhensible” (article 12 RGPD).	Prévoir une version simplifiée ou visuelle de la politique : icônes, questions-réponses, schéma du cycle de vie des données (collecte → stockage → suppression). Mettre en avant les droits du client avec un bouton “Exercer mes droits”.
11	Manque de paragraphe distinct sur la “minimisation et privacy by design”	Faible	Pas d’impact direct sur la légalité, mais absence de démonstration du principe d’intégration de la protection dès la conception (article 25 RGPD).	Créer une section dédiée dans la politique : “B&B HOTELS limite la collecte aux données strictement nécessaires et intègre la sécurité dès la conception de ses systèmes.”

Légende des priorités :

- Haute priorité : Risque élevé.
Ces non-conformités présentent un risque élevé (juridique, réputationnel ou sécurité des données) et concernent les éléments essentiels comme le registre des traitements, le consentement des données sensibles ou la sécurité informatique. Elles doivent être corrigées **immédiatement**.
- Priorité moyenne : Points de vigilance.
Ces non-conformités nécessitent des actions planifiées pour sécuriser la conformité (procédures internes, formation du personnel, désignation d’un référent). L’impact est modéré et peut entraîner des erreurs ou des délais dans le traitement des données.
- Faible priorité : Points d’amélioration. Ces non-conformités présentent un risque limité mais leur correction renforce la transparence, la traçabilité et la conformité continue.
Elles concernent principalement des ajustements mineurs (information, documentation, clarté des formulaires).

Conclusion

À l'issue de cette étude, il ressort que le site **B&B HOTELS Boutique** présente un niveau de conformité RGPD globalement satisfaisant, reposant sur des politiques de confidentialité et de cookies détaillées, l'usage d'une plateforme de consentement (**Cookiebot**) et le respect des normes de sécurité PCI DSS pour les paiements.

Cependant, plusieurs **axes d'amélioration** doivent être consolidés afin de renforcer la **traçabilité, la sécurité et la transparence** des traitements.

Les principales actions à maintenir ou à renforcer sont les suivantes :

1. Politique de confidentialité et transparence accrue

Maintenir une politique claire et accessible depuis toutes les pages collectant des données (réservation, contact, newsletter, spa), en y ajoutant la **liste consolidée des prestataires** (ex. : Hotels at Home Inc., Google LLC) et les **mécanismes d'encadrement des transferts hors UE**.

2. Gestion du consentement aux cookies

Conserver le dispositif actuel **Cookiebot**, tout en vérifiant techniquement que **les cookies analytiques et marketing ne sont déposés qu'après consentement explicite**.

Le journal des consentements (Consent ID) doit être conservé 13 mois comme preuve d'accountability.

3. Collecte sécurisée et proportionnée des données

- Utiliser le **HTTPS/TLS** sur toutes les pages du site.
- Limiter la collecte aux données strictement nécessaires.
- Pour les données sensibles (allergies, santé), obtenir un **consentement explicite** et restreindre l'accès au seul personnel concerné.

4. Renforcement des accès administratifs

- Activer une **authentification à deux facteurs (2FA)** sur les comptes du back-office et du CMS.
- Journaliser les connexions et restreindre les accès par profil utilisateur.
- Maintenir les **mise à jour régulières** du site et des serveurs hébergés dans l'UE.

5. Sauvegarde, chiffrement et gestion des incidents

- Conserver les données clients sur des serveurs sécurisés, **chiffrés et sauvegardés régulièrement**.
- Disposer d'une **procédure documentée** pour la notification d'incidents de sécurité dans les 72 heures (article 33 RGPD).

6. Exercice des droits et contact RGPD

Mettre en avant un **point de contact unique** pour les droits des personnes :

Hotels at Home – Global Data Protection Manager, 163 rue de la Belle Étoile, 95700

Roissy-en-France, ou via customer.service@bbhotelsboutique.com.

Ce contact permet aux clients d'exercer facilement leurs droits d'accès, de rectification, d'effacement ou d'opposition.

En consolidant ces dispositifs, B&B HOTELS renforce non seulement sa conformité au RGPD, mais aussi la confiance numérique de sa clientèle, un facteur clé de compétitivité dans le secteur hôtelier.